

E-Commerce Brand Impersonation & Chinese SaaS Fraud Funnel

Case: SEC-2026-ECOM-005 · Target: Media Galaxy (Altex România) · Live Sandbox Verified: 16 Sept 2026

Incident Type: Social Media Phishing / Brand Impersonation	Financial Impact: ~21 EUR (~105 RON)
Target Lure Platform: TikTok Sponsored In-App Ads	Payment Rail: BCR Debit Card (Direct)
Phishing Landing FQDN: mediagalaxy.voetbalshop-nlco.com	Backend C2 SaaS: yiyangsaas.com (Yunnan, CN)
Investigator: @stefanutc1 (Senior Security Engineer)	Verification Mode: Airtight Headless Chrome Sandbox

1. Executive Summary

On 16 September 2026, an automated fraud campaign targeting Romanian citizens was detected and triaged. Threat actors weaponized high-volume sponsored advertisements within the **TikTok** mobile platform, cloning the brand, promotional visuals, and e-commerce identity of **Media Galaxy** (Altex România S.A.). Victims clicking the sponsored link were funneled via the mobile in-app browser to mediagalaxy.voetbalshop-nlco.com, a localized fraudulent checkout portal designed to steal payment card data and Personally Identifiable Information (PII).

A debit of approximately **21 EUR** was executed directly against the victim's BCR (Banca Comercială Română) debit card under the shell merchant descriptor '**morvethemi london**'. Immediately following payment authorization, the storefront switched to a deceptive maintenance screen ('The website is under maintenance'). Simultaneously, automated mail relays dispatched confirmation tokens ([229942-177457]) and password reset verification codes (586571) from spoofed domains (email.worvixglobal.com, info.mailapp-fly.com) to attempt secondary account takeover.

2. Live Web Verification & Infrastructure Forensics

A. Airtight Browser Probe & Shared Origin Proof: Operating in an isolated headless Chrome sandbox, active network probes confirmed that mediagalaxy.voetbalshop-nlco.com and the central C2 domain yiyangsaas.com resolve to the **exact same IP (104.16.145.247)** on Cloudflare, definitively proving co-located infrastructure.

B. Targeted TikTok Ad Preloader & OEMCart Codebase: Live DOM extraction revealed the explicit tag <meta name="tiktok-ads-preloading-nocache" content="1">, proving purposeful weaponization of TikTok's in-app webview. Deobfuscating client scripts exposed the base64-decoded token oemcart_ and asset path /skins/default/guoqi.png (*guoqi* = national flag in Chinese pinyin), confirming the application is built on China's OEMCart turnkey fraud suite.

C. Fresh Certificate Issuance & Burned Relays: Live X.509 certificate extraction revealed that the SSL certificate for mediagalaxy.voetbalshop-nlco.com was issued on **September 15, 2026 at 00:43:20 GMT** (under 24h before the debit). Meanwhile, secondary email dispatch domains (info.mailapp-fly.com, email.worvixglobal.com) have already been burned to NXDOMAIN.

3. Evidence Matrix (Desktop Screenshots & Live Probes)

Evidence ID	Source / Artifact	Forensic Finding & Intelligence Value
01-02_worvixglobal	Desktop / WHOIS	Shell trade facade registered at NameSilo (2025-02-08) to bypass NRD spam filters.
03-06_email_lures	Desktop / SMTP	DKIM relay info.mailapp-fly.com, Reply-To MaryxBeckb96@gmail.com, fake token [229942-177457].
07-10_dom_source	Desktop / DevTools	Subdomain mediagalaxy, , module_login_default, Cloudflare CDN.
14_merchant_descriptor	Desktop / Search	'morvethemi london' has zero registered business records; offshore shell descriptor.
19-22_c2_attribution	Desktop / Certs	Port 443 query revealed cn: yiyangsaas.com; eName Technology registrant in Yunnan, China.
23-24_ato_lure	Desktop / Mail	Password reset code 586571 delivered to victim with spoofed MEDIACALAXY logo.

LIVE_01_shared_ip	Chrome Sandbox	Shared IP 104.16.145.247 co-locating phishing frontend with yiyangsaas.com backend.
LIVE_02_tiktok_tag	Live DOM Extraction	Meta tag tiktok-ads-preloading-nocache=1 and decoded oemcart_ Chinese engine scripts.
LIVE_03_cert_dump	Live OpenSSL Probe	Fresh Google Trust cert issued Sep 15 2026; subdomains info.mailapp-fly.com burned.

4. Indicators of Compromise (IoCs)

Indicator	Type	Threat Role	Enforcement Action
mediagalaxy.voetbalshop-nlco.com	FQDN	Phishing Landing Subdomain	DNS Sinkhole (0.0.0.0)
voetbalshop-nlco.com	Domain	Base Infrastructure	Gateway Unbound Block
yyiangsaas.com	Domain	Backend C2 / Phishing SaaS	Outbound Egress Drop
worvixglobal.com	Domain	Attacker Shell & Mail Domain	DNS Sinkhole & Mail Filter
email.worvixglobal.com	FQDN	Order Fake Confirmation MTA	Quarantine at Mail Gateway
info.mailapp-fly.com	FQDN	ATO Verification Dispatcher	Quarantine at Mail Gateway
noreply@email.worvixglobal.com	Email	Phishing Sender	SMTP Sender Blacklist
noreply@info.mailapp-fly.com	Email	Phishing Sender	SMTP Sender Blacklist
MaryxBeckb96@gmail.com	Email	Attacker Drop Inbox	Report to Google Trust & Safety
brekerfurught@outlook.com	Email	Attacker Drop Inbox	Report to Microsoft Abuse
104.16.145.247 / 104.21.14.99	IPv4	Cloudflare Reverse Proxy IPs	Firewall Floating Reject Rule
morvethemi london	Descriptor	Fraudulent Bank Card Charge	Dispute / Chargeback Filing

5. Incident Response & Chargeback Playbook

Phase 1: Card Lockdown & Session Invalidation: The compromised debit card was immediately frozen and blocked through the George BCR banking application, followed by emergency cancellation and reissuance, preventing subsequent recurring billing attempts. All active Google/Gmail sessions for the victim were revoked, and FIDO2/Passkey authentication was enforced.

Phase 2: Bank Dispute Filing (Visa/Mastercard Chargeback): A formal claim under **Visa Dispute Condition 13.1 / Mastercard Reason Code 4853 (Merchandise Not Received / Fraudulent Merchant)** was initiated through BCR customer support. Documentation including the deceptive order token [229942-177457], offline maintenance status, and personal Gmail reply-to headers were attached to secure a full refund of the ~21 EUR transaction.

Phase 3: Perimeter Defense Integration on OPNsense Gateway (192.168.1.1):

- **Unbound DNS:** Deployed domains.txt to sinkhole queries to 0.0.0.0 across LAN/DMZ networks.
- **Suricata IDS/IPS:** Injected signatures sid:1000951-1000956 to log and drop HTTP/TLS requests to fraudulent hosts.
- **Egress Filtering:** Applied floating firewall rules blocking TCP outbound traffic to Cloudflare proxy endpoints 104.16.145.247.

Phase 4: Takedown & External Escalation: Abuse notices were filed with Cloudflare Trust & Safety, NameSilo Abuse, eName Technology, and the Romanian National Cyber Security Directorate (**DNSC** - alerts@dnsc.ro).

Incident Status: MITIGATED & SINKHOLED

Report Generated: 16 September 2026

Approved By: @stefanutc1 (Lead IR)